PENETRATION TEST REPORT

Active Directory Security Assessment
Target: 10.0.0.5 (corp.example.com)
Date: August 17, 2026
Assessment ID: AD-20260817-TEST01

Exposure Score: 72/100 (HIGH)

METRIC	VALUE
Total Findings	6
Critical	2
High	3
Medium	1
Low	0
Attack Paths	2
Compound Risks	2
Tools Executed	7
Duration	18.4s

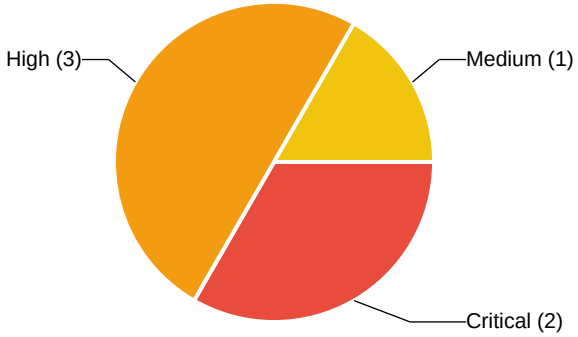
© Expedite Consults — Enterprise Security Assessment

1. EXECUTIVE SUMMARY

This assessment identified **2 critical** and **3 high** severity findings across the target Active Directory environment (10.0.0.5). **2 viable attack paths** were identified that could lead to full domain compromise. The overall exposure score is **72/100 (HIGH)**, indicating significant risk requiring prompt action.

AI Analysis: The combination of Kerberoastable privileged accounts with a weak 7-character password policy creates an immediate domain compromise risk. An attacker with any domain user account can request TGS tickets and crack them offline within hours.

1.1 Finding Distribution



2. SCOPE & METHODOLOGY

Target: 10.0.0.5 (corp.example.com)
Mode: Passive (read-only enumeration and analysis)
Tools Executed: 7 automated security checks
Duration: 18.4 seconds
Methodology: PTES, OWASP, MITRE ATT&CK;, NIST CSF, CIS Controls
Phases: Discovery → Analysis → Correlation → Scoring

2.1 Discovery Summary

Asset Type	Count
Users	847
Groups	134
Computers	312
Domain Controllers	3
GPOs	28
Trusts	1
SPNs	23

3. DETAILED FINDINGS

[CRITICAL] 1. Privileged Kerberoastable: svc_backup

MITRE: T1558.003 | **NIST:** PR.AC-7 | **CIS:** 16.2 | **Confidence:** 100% | **Source:** enumerate_spns

Affected: svc_backup

Privileged account svc_backup has SPN MSSQLSvc/db01:1433. TGS can be cracked offline for domain compromise.

Remediation: Remove SPN from svc_backup or convert to gMSA. Enforce AES-only encryption.

[CRITICAL] 2. Unconstrained Delegation: WEB01

MITRE: T1550.003 | **NIST:** PR.AC-4 | **CIS:** 6.8 | **Confidence:** 100% | **Source:** analyze_kerberos

Affected: WEB01

TGTs of authenticating users stored in memory. Attacker on WEB01 can impersonate ANY domain user.

Remediation: Remove unconstrained delegation. Use constrained delegation or RBCD.

[HIGH] 3. Anonymous LDAP Bind Allowed

MITRE: T1087.002 | **NIST:** PR.AC-1 | **CIS:** 16.8 | **Confidence:** 100% | **Source:** analyze_ldap

Affected: 10.0.0.5

Attackers can enumerate users, groups, OUs without credentials.

Remediation: Disable anonymous LDAP bind. Require authentication.

[HIGH] 4. Weak Password Length: 7 characters

MITRE: T1110 | **NIST:** PR.AC-1 | **CIS:** 5.2 | **Confidence:** 100% | **Source:** analyze_passwords

Affected: Default Domain Policy

Min password length is 7. NIST recommends 12+.

Remediation: Set minimum password length to 14+ characters.

[HIGH] 5. SMB Signing Not Enforced

MITRE: T1557.001 | **NIST:** PR.DS-2 | **CIS:** 9.2 | **Confidence:** 80% | **Source:** analyze_smb

Affected: 10.0.0.5

NTLM relay attacks possible if signing not enforced.

Remediation: Enforce SMB signing via GPO.

© Expedite Consults — Enterprise Security Assessment

[MEDIUM] 6. Outdated Functional Level: 2008R2

MITRE: T1484.001 | **NIST:** PR.IP-1 | **CIS:** 4.1 | **Confidence:** 100% | **Source:** discover_domain

Affected: DC=corp,DC=example,DC=com

Lacks modern security features.

Remediation: Raise domain functional level to 2016 or higher.

---

4. ATTACK PATHS

■ Kerberoasting -> Domain Admin (Risk: 95/100, Confidence: 95%)

Chain: Domain User → svc_backup SPN → Cracked Creds → Domain Admin

`MITRE: T1558.003 → T1110.002 → T1078.002 → T1003.006`

■ Unconstrained Delegation -> DA (Risk: 95/100, Confidence: 90%)

Chain: Domain User → WEB01 → Admin TGT → Domain Controller

`MITRE: T1078 → T1550.003 → T1003.006`

4.1 Compound Risk Correlations

[CRITICAL] Kerberoast + Weak Password Policy

Kerberoastable accounts combined with 7-char minimum password makes offline cracking trivial.

[CRITICAL] Anonymous LDAP + SMB Signing Not Enforced

Anonymous LDAP enables recon. Lack of SMB signing enables NTLM relay to LDAP for object modification.

5. REMEDIATION ROADMAP

IMMEDIATE (0-48 hours)

• **Privileged Kerberoastable: svc_backup:** Remove SPN from svc_backup or convert to gMSA. Enforce AES-only encryption.

• **Unconstrained Delegation: WEB01:** Remove unconstrained delegation. Use constrained delegation or RBCD.

SHORT-TERM (1-2 weeks)

• **Anonymous LDAP Bind Allowed:** Disable anonymous LDAP bind. Require authentication.

• **Weak Password Length: 7 characters:** Set minimum password length to 14+ characters.

• **SMB Signing Not Enforced:** Enforce SMB signing via GPO.

MEDIUM-TERM (1-3 months)

• **Outdated Functional Level: 2008R2:** Raise domain functional level to 2016 or higher.

5.1 Exposure Score Breakdown

Category	Score	Max
Privileged Accounts	12	25
Trust & Delegation	22	25
Configuration	20	25
Anomalies	18	25
TOTAL	**72**	**100**